Appendix C: Communication Logs & Task Coordination Record

03CIT4067 Cybersecurity Project — Group 7 (Topic 15)

To maintain transparency and document the team's adaptability to resource constraints, the Team Leader (WONG Lai Man) records the following coordination efforts regarding member Zoutao.

1. Initial Communication & Context Clarification (October 16-20, 2026)

- **Issue:** Initial communication delay regarding meeting availability and task updates.
- **Resolution:** Contacted via WhatsApp on October 20. Zoutao clarified that he was hospitalized for medical treatment and experienced network connectivity issues in Mainland China.

2. Technical Constraints & Task Reallocation (October 20, 2026)

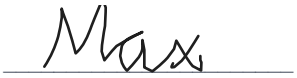
- **Challenge:** Zoutao reported inability to deploy OWASP Juice Shop via Docker due to regional network restrictions blocking foreign image registries (Docker Hub) and SSL certificate validation issues.
- **Mitigation Strategy:** As Team Leader, I reallocated local environment deployment to Mustafa (who successfully deployed it in Hong Kong). Zoutao was reassigned to focus on documentation and Red Team operation logs, which do not require local Docker execution.

3. Written Deliverables Received from Zoutao

- Zoutao successfully submitted two text files containing detailed Red Team (Attacker) operation steps for OWASP Top 10 categories (A01-A10).
- These documents are actively integrated into Chapter 5 (Implementation) and Appendix B of the Phase 2 Report as primary Attack Methodology references.

Declaration:

I, WONG Lai Man, declare that the above records reflect the team's agile adaptation to member constraints. Zoutao has contributed written deliverables despite technical barriers, and his work is being integrated into the final product.

Signature:  **Date: 2026-10-20**

(WONG Lai Man - Team Leader)

Docker 拉取镜像连不上国外仓库，网络问题，这条路也卡住了。

A01/A02/A03（OWASP Top10 2025）

OWASP Top10 2025 实验报告 — Juice Shop

实验目标

在 OWASP Juice Shop 靶场中完成 A01 访问控制失效、A02 安全配置错误、A03 软件供应链失效三个漏洞挑战，理解漏洞成因、危害与防御方案。

A01 Broken Access Control 访问控制失效

漏洞描述

访问控制用于限制用户只能在其权限范围内执行操作。该应用没有对后台管理页面进行权限校验，任意普通登录用户，都可以通过直接访问 URL 的方式进入管理员后台，属于垂直越权漏洞，对应 OWASP Top10 2025 A01。

操作步骤

1. 打开 Juice Shop，注册普通用户账号并登录。

2. 在浏览器地址栏直接访问后台路由：/#/administration

3. 页面成功加载管理员后台，挑战自动标记完成。

漏洞危害

攻击者无需管理员账号密码，直接访问后台，查看、修改用户数据，管理站点。

修复方案

1．后端接口增加身份+权限校验，每个请求校验当前用户角色；

2．前端路由增加守卫，无权限用户禁止访问后台页面；

3．禁止依靠前端隐藏链接做权限控制。

A02 Security Misconfiguration 安全配置错误

漏洞描述

Web 应用默认配置不安全、缺少必要的安全头、文件上传校验缺失等都属于安全配置错误。本关投诉上传功能未限制上传文件类型，允许上传 XML 文件，属于安全配置错误，对应 OWASP Top10 2025 A02。

操作步骤

1．登录账号，打开导航栏的 Complaint（投诉）页面。

2．在本地新建 test.xml，写入内容：

<message>test xml upload</message>

3．投诉文本框随意填写内容，选择 test.xml 作为附件上传并提交。

4．提交成功，挑战解锁完成。

漏洞危害

恶意上传 xml 文件，可能触发 XXE、文件解析漏洞，读取服务器敏感文件。

修复方案

1．后端校验文件后缀、MIME 类型、文件头；

2．上传文件重命名，单独存放，禁止服务器解析上传目录文件；

3．关闭不必要的解析功能。

A03 Software Supply Chain Failures 软件供应链失效

漏洞描述

软件开发依赖大量第三方组件、库、包。如果第三方组件存在漏洞，会连累主应用，这就是软件供应链风险。Juice Shop 依赖 lodash 4.17.21，该版本存在原型污染漏洞，对应 OWASP Top10 2025 A03。

操作步骤

1．靶场页面按下 F12 打开开发者工具，切换到 Sources 面板。

2．全局搜索 lodash，打开 lodash.js 文件。

3．在文件头部找到版本号：4.17.21。

4．打开计分板（Score Board），提交答案 4.17.21，挑战通关。

漏洞危害

原型污染可实现代码执行、绕过校验，攻击者利用第三方库漏洞攻击网站。

修复方案

1．使用依赖扫描工具（Dependabot、Snyk）定期扫描依赖；

2．及时升级存在漏洞的第三方库；

3．锁定依赖版本，最小化引入第三方组件。

A04 加密机制失效 Cryptographic Failures

漏洞描述

敏感数据未使用安全加密算法，弱加密、明文存储、HTTPS 配置错误等。靶场中可以找到用户密码弱哈希（MD5）。

操作步骤

1．抓包或者查看用户数据库导出数据，拿到密码哈希值。

2．识别哈希为 MD5，在线解密直接还原明文密码。

危害

哈希容易被彩虹表碰撞，泄露用户账号密码。

修复

使用 Argon2、bcrypt 等慢哈希算法加盐存储密码；传输全程 HTTPS。

A05 注入 Injection（SQL 注入）

漏洞描述

程序直接拼接用户输入到 SQL 语句，没有预编译，攻击者可读写数据库。

操作步骤

1．搜索框输入注入 payload：

```
' OR 1=1--
```

2．查询直接返回全部商品数据，绕过查询条件。

危害

拖库、篡改数据、获取管理员账号。

修复

使用参数化查询（预编译 SQL），输入过滤，最小权限数据库账号。

A06 不安全设计 Insecure Design

漏洞描述

从产品设计阶段就存在安全缺陷，不是代码 bug，是架构逻辑缺陷。

操作步骤

1．购物下单修改商品单价，抓包修改 price 参数为 0。

2．可以 0 元下单购买商品。后端没有校验价格真实性，属于设计缺陷。

危害

业务逻辑被绕过，造成资金损失。

修复

服务端校验核心业务数据，价格、库存等不能由前端控制。

A07 认证机制失效 Authentication Failures

漏洞描述

认证逻辑存在缺陷，弱口令、暴力破解、会话固定、可撞库。

操作步骤

1．登录页面尝试暴力破解管理员账号 admin@juice-sh.op，密码 admin123。

2．直接登录管理员账号。

危害

攻击者直接拿下管理员账户。

修复

密码复杂度策略、登录失败限流、验证码、MFA 多因素认证。

A08 软件与数据完整性失效 Software and Data Integrity Failures

漏洞描述

升级包、插件、数据没有校验签名，数据被篡改后服务照常加载。

操作步骤

1．上传文件场景，修改前端文件名称与内容，后端没有校验文件哈希签名。

2．恶意文件成功上传并被服务读取。

危害

加载恶意代码、执行恶意逻辑。

修复

重要文件/更新包增加数字签名、哈希校验；CDN、依赖包开启完整性校验。

A09 安全日志与告警失效 Security Logging and Monitoring Failures

漏洞描述

系统没有对登录异常、注入、越权等攻击行为记录日志，攻击发生后无法溯源、告警。

操作步骤

1．尝试多次暴力破解、注入攻击。

2．系统无日志记录，后台无告警信息。

危害

入侵发生之后很难发现，无法追溯攻击来源。

修复

记录登录、增删改、高危操作日志；日志集中存储；配置异常行为告警。

A10 服务端请求伪造 SSRF Server-Side Request Forgery

漏洞描述

服务端访问用户可控 URL，攻击者利用服务端身份访问内网、元数据接口。

操作步骤

1. 靶场的反馈/远程图片加载功能，填入内网地址 http://127.0.0.1:3000。

2. 服务端发起请求访问本地/内网资源。

危害

探测内网、读取内网服务信息。

修复

URL 白名单、禁止访问内网与回环地址、DNS 重绑定防护。

本次实验完成了 OWASP Top10 2025 中 A01、A02、A03 的漏洞复现。访问控制失效、不安全配置、供应链漏洞都是 Web 系统高频风险，开发时不能只关注业务功能，必须做好权限校验、输入/文件校验、依赖管理。